Layer 2 Attacks

IE3122 – Network Security | Week 3

VLANs, switching, and the attacks that target them

Today's Agenda

- Why Layer 2 matters, and a VLAN refresher
- The Layer 2 attack landscape
- CAM table (MAC flooding) attacks
- VLAN hopping attacks (switch spoofing & double tagging)
- DHCP-based attacks (starvation & spoofing)
- ARP spoofing
- Bringing it together: layered Layer 2 defense

Learning Outcomes for Today

LO1

- Describe common network vulnerabilities and attacks — today, specifically at Layer 2.

LO2

- Evaluate different mitigation techniques for vulnerabilities and make recommendations.

- *By the end of this session you should be able to explain how each attack works, what it exploits, and compare mitigation options — from a simple config change to a more complete technical control.*

Layer 2 & VLAN Foundations

What we're protecting, and why it's an attractive target

Why Layer 2 Matters in Modern Networks

- Every packet, regardless of what's happening at Layer 3 and above, ultimately has to move as an Ethernet frame between two directly connected devices — Layer 2 is the ground floor.
- Layer 2 protocols (Ethernet, ARP, DHCP, VLAN trunking) were largely designed for trusted, physically-controlled networks — most have little to no built-in authentication.
- A compromise at Layer 2 can undermine security controls running above it — e.g. intercepting traffic at Layer 2 defeats a Layer 3 ACL that never gets a chance to inspect it.
- This is why LO2 matters here: knowing an attack is possible isn't enough — you need to evaluate which mitigation actually closes the gap, and at what cost/complexity.

VLANs: What and Why

- A VLAN (Virtual LAN) splits a single physical switch into multiple logical broadcast domains — devices on different VLANs can't reach each other without going through a router (recall Week 1's broadcast-domain revision).
- Used for segmentation: separating staff, guests, servers, and IoT devices so a compromise in one segment doesn't automatically expose the others.
- Each VLAN is identified by a VLAN ID (1–4094); frames are tagged with this ID as they cross trunk links between switches.
- Segmentation is a security control in its own right — but as we'll see today, VLANs have their own attack surface if misconfigured.

VLAN Protocols Overview

Protocol	Purpose
802.1Q	The standard for tagging Ethernet frames with a VLAN ID as they cross trunk links
VTP (VLAN Trunking Protocol)	Propagates VLAN configuration across multiple switches automatically
DTP (Dynamic Trunking Protocol)	Automatically negotiates whether a link becomes a trunk — convenient, but exploitable (see VLAN hopping)

Trunking & the Native VLAN

- A trunk link carries traffic for multiple VLANs between switches, using 802.1Q tags so each switch knows which VLAN a frame belongs to.
- The native VLAN is the one exception: frames on the native VLAN are sent untagged across a trunk — a legacy compatibility feature.
- That untagged exception is exactly what the VLAN double-tagging attack (later today) abuses — keep this in mind.
- By default, many switches use VLAN 1 as both the default access VLAN and the default native VLAN — a configuration habit that turns out to matter a lot for security.

The Layer 2 Attack Landscape

Six attacks, one underlying theme

Why Attackers Target Layer 2

- MAC addresses, ARP, and DHCP all operate with essentially no built-in authentication — a device is largely trusted just for being on the wire.
- Layer 2 attacks are often cheap to execute: many need nothing more than a laptop on an access port and freely available tools.
- A successful Layer 2 attack frequently becomes the foothold for something bigger — traffic interception, credential theft, or a pivot to Layer 3.
- The common defensive theme across today's six attacks: verify what a device claims (MAC, VLAN, IP-to-MAC binding) instead of trusting it by default.

Six Attacks at a Glance

Attack	What it targets
CAM Table (MAC Flooding)	The switch's MAC address table
VLAN Hopping — Switch Spoofing	DTP trunk negotiation
VLAN Hopping — Double Tagging	The native VLAN's untagged handling
DHCP Starvation	The DHCP server's available IP pool
DHCP Spoofing	Clients trusting any DHCP reply
ARP Spoofing	Hosts trusting any ARP reply

MAC Address Attacks

Overwhelming the CAM table, and forging the identities it relies on

MAC Address Spoofing: Overview & Vulnerability

- Overview: MAC address spoofing is a very simple attack. The attacker changes their own device's MAC address to match a specific target, usually a trusted or already-authorised device.
- Vulnerability exploited: a MAC address is stored in software/firmware on most network interfaces and can be changed by the user with a single command on nearly every operating system. The network has no way to verify that a claimed MAC address genuinely belongs to the hardware presenting it.
- Use for thinks like network testing and breaking physical tracking of mobile devices via the MAC address
- Why this matters: many basic access controls (Wi-Fi MAC filtering, MAC-based ACLs, some port security setups) implicitly assume a MAC address is a reliable, hardware-tied identity. Spoofing directly breaks that assumption.

MAC Address Spoofing: Technique & Impact



- Technique: the attacker identifies a target MAC address (e.g. by sniffing local traffic), then uses a simple OS command to reconfigure their own network interface to present that MAC instead of its real one. No special tools or deep protocol knowledge required.
- Impact — bypassing controls: defeats MAC-filtered Wi-Fi/wired ports and MAC-based ACLs outright, since the attacker's traffic now carries an allowed address.
- Impact — session hijacking: if the attacker spoofs an already-connected device's MAC, the resulting address conflict can be exploited to intercept or redirect that device's traffic.
- Impact — evading attribution: logs and simple port-security checks show the legitimate device's MAC, not the attacker's own, making the activity harder to trace back.

MAC Address Spoofing: Mitigation

- Port security with sticky MAC and a low violation threshold helps, but isn't a complete fix — an attacker who waits until the legitimate device disconnects, or spoofs during an idle window, can still get through.
- 802.1X / centralised AAA authentication is the strongest fix: it ties network access to a verified user or device credential (e.g. a certificate or EAP method), not just a MAC address. Cloning a MAC alone is no longer enough to gain access.
- Monitoring for duplicate MAC addresses appearing on the network is a useful detective control — it flags exactly the anomaly a spoofing attack creates, even if it can't prevent the first attempt.
- The underlying lesson: relying on a MAC address alone as a trust signal is fundamentally fragile. This is exactly why centralised authentication (AAA, covered in full in Week 8) matters so much more than device-level filtering alone.

CAM Table Attack: Overview & Vulnerability

- Overview: also called MAC flooding — the attacker overwhelms a switch's MAC address table so it can no longer forward frames intelligently.
- Vulnerability exploited: a switch's CAM (Content Addressable Memory) table has a fixed size, and switches are designed to ‘fail open’ when it's full — prioritising availability over confidentiality.
- This is a design trade-off, not a bug: recall from Week 1 that switches learn source MACs automatically and with no verification of who's really sending them.

CAM Table Attack: Technique



Floods thousands of frames, each with a fake, unique source MAC

- The attacker sends a huge number of frames, each with a different, fabricated source MAC address.
- The switch dutifully learns every one of them until the CAM table fills completely.
- Once full, the switch can no longer learn new legitimate MACs and — to keep forwarding traffic at all — starts flooding unknown-destination frames out every port, just like a hub.
- The attacker, sitting on any port, now receives a copy of traffic never meant for them — a passive eavesdropping win with no need to intercept anything actively.

CAM Table Attack: Mitigation

Technique	How it helps
Port Security (simple)	Limit each access port to a maximum number of learned MAC addresses — e.g. 1–2 — stopping the flood before the table fills
Sticky MAC + violation action	Lock the first learned MAC(s) permanently; configure the port to shut down or restrict traffic on a violation

- This is the exact configuration you'll apply in this week's lab — port security is a simple, low-cost control with a big payoff against this specific attack.
- Port security doesn't address VLAN hopping, DHCP, or ARP attacks — it's one layer, not a complete Layer 2 defense on its own.

VLAN Hopping Attacks

Reaching traffic you were never meant to see

VLAN Hopping: Overview

- Goal: send or receive traffic on a VLAN the attacker's port was never assigned to — bypassing the segmentation VLANs are meant to provide.
- Two distinct techniques achieve this: switch spoofing (abusing DTP) and double tagging (abusing native VLAN handling) — different vulnerability, different fix.

Switch Spoofing: Vulnerability & Technique

- Vulnerability exploited: DTP will automatically negotiate a trunk if the port on the other end signals willingness to trunk — with no authentication of who's asking.
- Technique: the attacker's PC runs software that mimics a switch speaking DTP. If the access port they're connected to has DTP enabled (often the default), the switch obligingly turns that port into a trunk.
- Once trunked, the attacker's device receives tagged traffic for every VLAN carried on that trunk — not just the one it was originally assigned.

Double Tagging: Vulnerability & Technique



Attacker crafts a frame with two 802.1Q tags

- Vulnerability exploited: the native VLAN is sent untagged across a trunk — the first switch strips only the outer tag, assuming that's all there is.
- Technique: the attacker (on a port assigned to the native VLAN) crafts a frame with two stacked 802.1Q tags — an outer tag matching the native VLAN, and an inner tag for the target VLAN.
- The first switch strips the outer (native) tag and forwards the frame — still carrying the inner tag — onward. The next switch reads that inner tag and delivers the frame straight into the target VLAN.
- This is a one-way attack (no reply path back the same way), but it's enough to inject traffic into a VLAN the attacker shouldn't reach — and it only works if the attacker's port sits on the native VLAN.

VLAN Hopping: Mitigation

Technique	Addresses
Disable DTP (switchport nonegotiate)	Switch spoofing — stops ports from ever auto-negotiating into a trunk
Manually configure trunk/access mode explicitly	Switch spoofing — removes ambiguity DTP would otherwise resolve automatically
Change the native VLAN off VLAN 1, to an unused VLAN	Double tagging — attacker's access port is no longer on the native VLAN by default
Explicitly tag the native VLAN on trunks (where supported)	Double tagging — removes the untagged exception the attack depends on
Shut down / move unused ports to an unused VLAN	Both — reduces the number of ports an attacker could exploit at all

DHCP-Based Attacks

Starvation and spoofing

DHCP Recap: Why It's Vulnerable

- Recall the DORA process from Week 1: Discover → Offer → Request → Acknowledge.
- DHCP has no built-in authentication at any of those four steps — a server doesn't prove it's authorised to answer, and a client doesn't prove who it is.
- That single gap is enough to enable two distinct attacks: exhausting the legitimate server's pool (starvation), and impersonating the server entirely (spoofing).

DHCP Starvation: Vulnerability & Technique

- Vulnerability exploited: a DHCP server has no way to tell that many different DHCP Discover messages, each with a different spoofed source MAC, are really all coming from one attacker.
- Technique: the attacker floods the network with DHCP Discover requests using a different fabricated MAC address each time.
- The legitimate server, doing exactly what it's designed to do, leases out an address for each request — until its entire address pool is exhausted.
- Result: legitimate new clients can no longer get an IP address at all — this is fundamentally a Denial of Service on the addressing system itself.

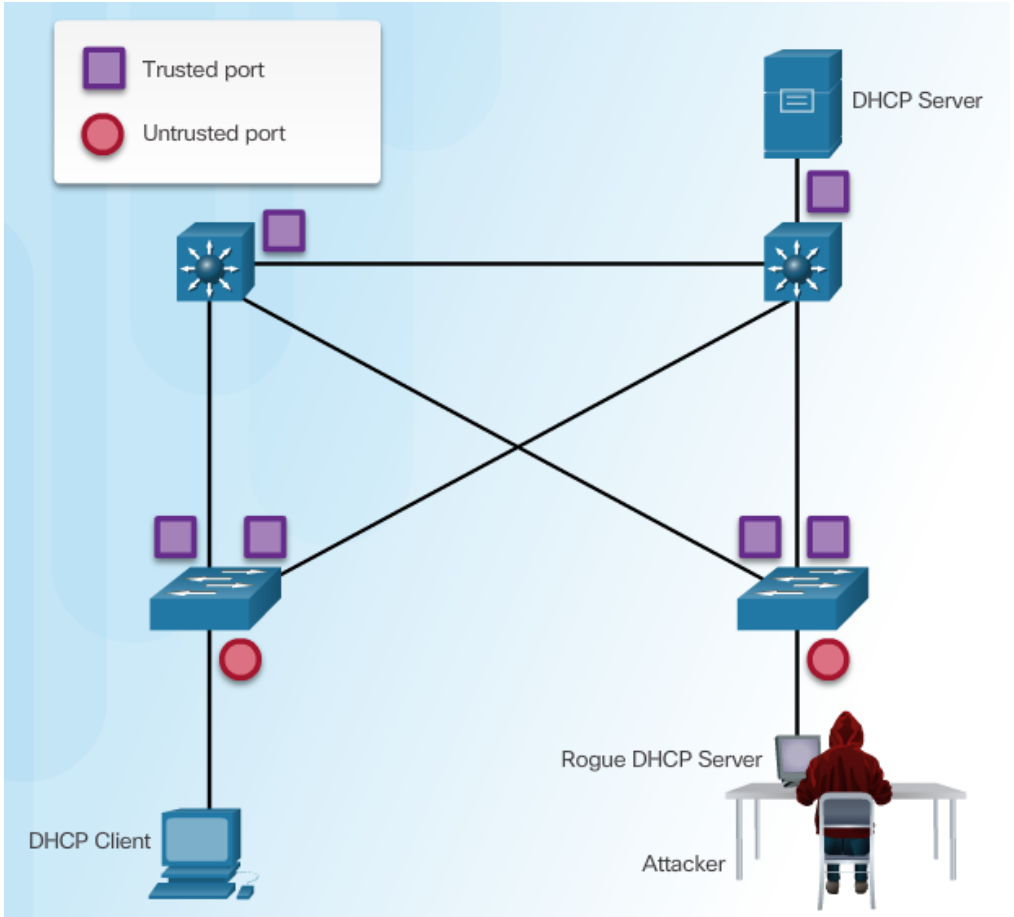
DHCP Spoofing: Vulnerability & Technique

- Vulnerability exploited: a client accepts a DHCP Offer from whichever server replies first — it has no way to check the offer came from the authorised server.
- Technique: the attacker runs their own rogue DHCP server. If it answers a client's Discover before the real server does, the client accepts the rogue offer instead.
- The rogue server hands out a normal-looking IP address — but with the attacker's own machine set as the default gateway and/or DNS server.
- Result: the victim's traffic is silently routed through the attacker — a man-in-the-middle position, often paired with starvation to make sure the rogue server wins the race (recall this was previewed as a security concern back in Week 1).

DHCP Attacks: Mitigation — DHCP Snooping

- DHCP Snooping classifies switch ports as trusted (uplinks toward the real DHCP server) or untrusted (access ports where end users/clients connect).
- DHCP server responses (Offer, Acknowledge) are only permitted from trusted ports — a rogue server plugged into an untrusted access port has its replies silently dropped, directly stopping DHCP spoofing.
- The switch also builds a binding table (MAC ↔ IP ↔ VLAN ↔ port) from legitimate DHCP transactions — this becomes the trust source for Dynamic ARP Inspection shortly.
- Rate-limiting DHCP messages per port helps blunt starvation attempts by capping how fast one port can generate Discover floods.

DHCP Snooping: Configuration



ARP Spoofing

The classic man-in-the-middle setup

ARP Spoofing: Vulnerability & Technique



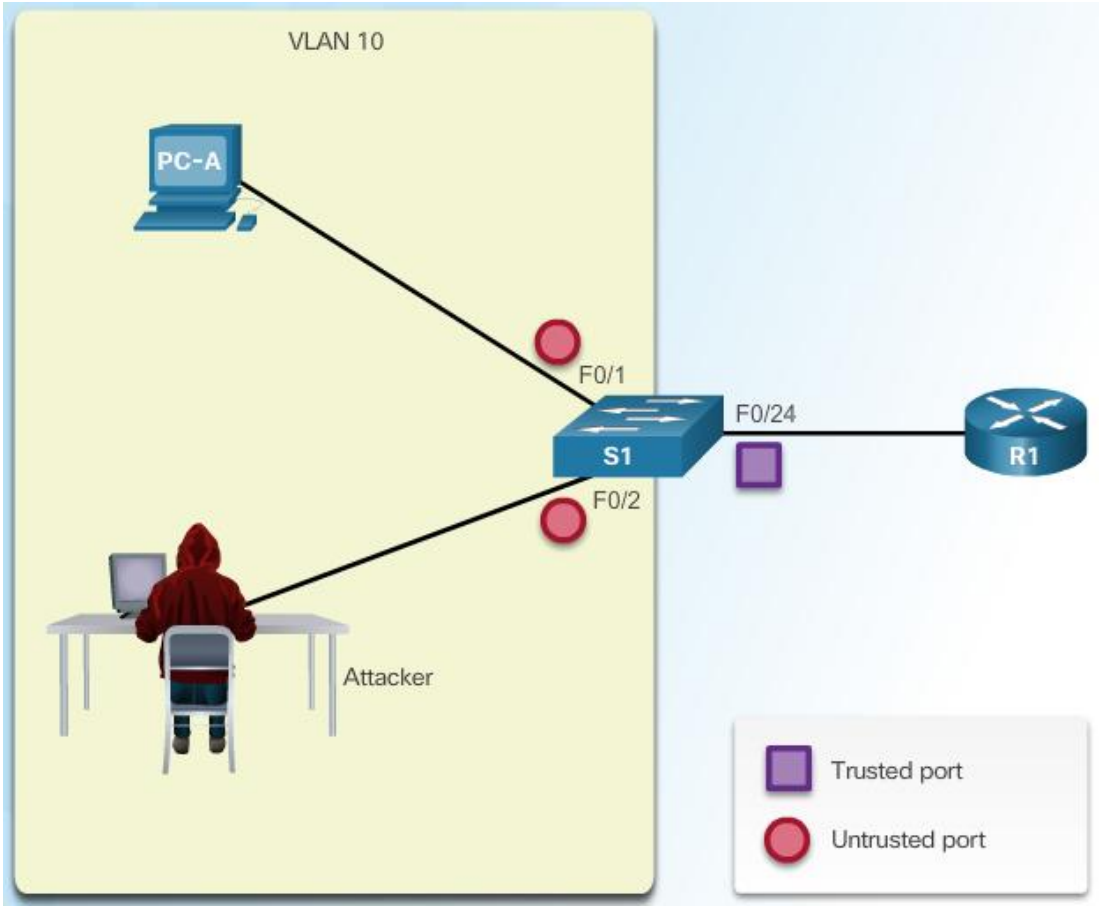
Forged ARP replies redirect both victims' traffic through the attacker

- Vulnerability exploited: hosts accept unsolicited ARP replies and update their ARP cache without verifying the reply was ever requested.
- Technique: the attacker sends forged (gratuitous) ARP replies to two victims, each telling them the attacker's MAC address belongs to the other victim's IP.
- Both victims now send traffic intended for each other straight to the attacker instead — who can read it, alter it, or simply forward it on so neither victim notices.

ARP Spoofing: Mitigation — Dynamic ARP Inspection

- Dynamic ARP Inspection (DAI) checks every ARP packet on untrusted ports against the DHCP snooping binding table built earlier — this is why DHCP snooping is typically configured first.
- If an ARP reply's claimed IP-to-MAC mapping doesn't match what the binding table says that device was actually leased, the switch drops the packet before it ever reaches its target.
- This directly stops ARP spoofing without needing every host to run its own protection — the enforcement happens at the switch.
- Together, DHCP Snooping + DAI is a clean example of layered defense: one control (snooping) builds the trusted data another control (DAI) depends on.

Dynamic ARP Inspection: Configuration



Multi-Function Attacks

Why the same technique can serve more than one goal

Attacks with Multiple Outcomes (1/2)

Attack	Primary Outcome	Secondary Outcome	Why it can go either way
CAM Table (MAC Flooding)	MITM / Eavesdropping	DoS	Overflow floods traffic to the attacker; sustained flooding also degrades switch performance
MAC Address Spoofing	Access / Impersonation	Enabler for further attacks	Bypasses filtering directly; the identity theft also sets up hijacking and evades attribution
VLAN Hopping (Switch Spoofing)	Access / Reconnaissance	Enabler for further attacks	Grants visibility into every VLAN on the trunk; that foothold enables lateral movement
VLAN Hopping (Double Tagging)	Injection	Enabler for further attacks	One-directional injection into an isolated VLAN; sets up a further exploit against hosts there

Attacks with Multiple Outcomes (2/2)

Attack	Primary Outcome	Secondary Outcome	Why it can go either way
DHCP Starvation	DoS	Enabler for further attacks	Exhausts the address pool outright; often paired with DHCP Spoofing to guarantee it wins the race
DHCP Spoofing	MITM	DoS	Normally positions the attacker as gateway/DNS to intercept traffic; a broken rogue config just cuts victims off instead
ARP Spoofing	MITM / Eavesdropping	DoS	Classic bidirectional interception between two victims; the same forged mapping can instead blackhole traffic

Every attack covered this week appears in at least one of these tables with more than one plausible outcome.

Patterns and Implications

DoS	MITM / Eavesdropping	Access / Injection	Enabler for further attacks

- Every attack this week maps to at least two of these four outcome categories, not one — which outcome actually happens is usually decided by attacker intent, not by a difference in the technique itself.
- A CAM table attack run for two extra minutes is still a CAM table attack — but it stops being quiet eavesdropping and starts being a performance-degrading DoS. Same technique, different goal.
- Implication for mitigation: evaluating a control means asking whether it closes off every plausible outcome, not just the one demonstrated in lecture. Port security stops the CAM table attack full stop, regardless of which outcome the attacker was actually going for.
- **This is exactly the LO2 skill the costing exercise is built on — a mitigation's value depends on the full range of what it prevents, not a single labelled scenario.**

Bringing It Together

Comparing mitigations across all six attacks

SUMMARY

Full Mitigation Comparison

Attack	Simple config	Additional technique
MAC Address Spoofing	Port security (sticky MAC + violation action)	802.1X / centralised AAA authentication
CAM Table (MAC Flooding)	Port security (max MAC count)	Sticky MAC + violation action
VLAN Hopping (Switch Spoofing)	switchport nonegotiate	Manual trunk/access mode
VLAN Hopping (Double Tagging)	Change native VLAN off VLAN 1	Explicit native VLAN tagging
DHCP Starvation	Port security (limits spoofed MACs)	DHCP snooping rate-limiting
DHCP Spoofing	Restrict trusted ports	Full DHCP snooping deployment
ARP Spoofing	Static ARP (small networks only)	Dynamic ARP Inspection

DISCUSSION

Same Control, Different Purpose and Cost

Port Security Violation Action	What actually happens	Primary function shifts to...
Shutdown	Port is disabled entirely the moment a violation occurs	Preventive — stops the traffic outright
Restrict	Violating traffic is dropped, but the port stays up and a log/alert is generated	Detective — the value is now the visibility, not the block

- One keyword change moves the same feature from one column of Week 2's function taxonomy to another — the technology didn't change, only what it's actually doing for you did.
- Physical security can do the same job as several technical controls at once: if an attacker cannot physically reach a switch port or a cable, CAM table attacks, ARP spoofing, MAC spoofing, and rogue DHCP are all simultaneously off the table, without a single line of configuration.
- Neither of these is free, though. A stricter violation action can lock out legitimate devices; locked comms rooms and cable conduit cost money and slow down routine maintenance. Every mitigation trades security for some kind of cost, not just whether it ‘works.’
- **That's exactly what the next exercise asks you to work through.**

IN-CLASS ACTIVITY

Exercise: Costing Out Layer 2 Mitigations

- In your groups, take the mitigation techniques covered across today's Layer 2 attacks (including MAC address spoofing) and rate each one across three cost dimensions.
- Financial Cost — licensing, hardware, and ongoing costs to acquire and run the control.
- Configuration Cost — how much time and complexity it takes to set up correctly, including the risk of getting it wrong.
- Computational Cost — the processing/performance overhead the control adds to switches and the network.
- Use a simple scale for each: None, Low, Medium, or High.
- Be ready to justify at least two of your ratings to the class — why that rating, and what would change it?

This connects directly to LO2: evaluating a mitigation isn't just about whether it works, it's about whether it's worth deploying given real-world constraints.

IN-CLASS ACTIVITY

Exercise Worksheet

Mitigation Technique	Financial Cost	Configuration Cost	Computational Cost
Port Security (sticky MAC + violation action)			
Disable DTP / manual trunk-access mode			
Native VLAN hardening (move off VLAN 1 + explicit tagging)			
DHCP Snooping			
Dynamic ARP Inspection (DAI)			
802.1X / centralised AAA authentication			
Static ARP entries (small networks only)			

Fill in None / Low / Medium / High for each cell.

SUMMARY

Layered Defense at Layer 2

- No single control here covers every attack — exactly the layered-defense principle from Week 2, applied specifically to Layer 2.
- A practical baseline: port security on every access port, DTP disabled everywhere, native VLAN moved off VLAN 1, DHCP snooping enabled, and DAI layered on top.
- This baseline is what you'll configure hands-on in this week's lab — port security, DHCP snooping, and DAI together on a small topology.
- Evaluating *which* of these to prioritise for a given network — balancing security against operational complexity — is exactly the LO2 reasoning this module is building toward.

Summary

- Layer 2 protocols were built for trust, not verification — that gap is what every attack today exploited.
- CAM table attacks abuse a switch's fail-open design; VLAN hopping abuses trunk negotiation and native-VLAN handling; DHCP and ARP attacks abuse the total absence of authentication in both protocols.
- Mitigations range from a single config line (disabling DTP) to a small dependent chain (DHCP snooping enabling Dynamic ARP Inspection) — evaluating that trade-off is the LO2 skill.
- Layered defense isn't just a Layer 3+ concept — it applies just as much within a single switch.

This Week's Lab & Tutorial

- Lab (runs in the Week 4 session, based on this lecture): configure port security, DHCP snooping, and Dynamic ARP Inspection on a small Packet Tracer topology, then verify each with the appropriate show commands.
- Tutorial worksheet: study-notes-style questions covering VLANs, all six attacks, and their mitigations — use it to prep for the mid-semester test.

References

- Santos & Stuppi, CCNA Security 210-260 Official Cert Guide, 1st Ed., Cisco Press.
- Kaufman, Perlman, Speciner & Perlner, Network Security: Private Communication in a Public World, 3rd Ed., Prentice Hall.
- Cisco Networking Academy — CCNA Security curriculum (Layer 2 security chapters).